

FAKE CODEX XATTR CLEAR HUNTING

Campaign hunt for source-observed
removal of extended attributes from a
staged macOS Mach-O payload.

HUNTING QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

DeviceProcessEvents

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

25 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceProcessEvents

ATT&CK

T1553.001

Evidence-led dossier. Query status remains an untested
implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER



EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Hunt the directly observed anti-quarantine action.

Cato CTRL deobfuscated a Fake Codex ClickFix second stage that downloads a Mach-O to /tmp/helper, invokes xattr -c, applies chmod +x, and executes it. The hunt isolates the most direct process signal without relying on rotating domains or hashes.

OPERATIONAL VALUE

An actionable pre-execution pivot with an explicit attribution boundary.

The action occurs immediately before payload execution and combines trust-control impairment with a source-observed staging path. The path is mutable and tenant overlap is unknown, so the query remains a Medium-confidence hunt rather than a Production candidate.

9.3

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Hunting

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- A sponsored result and Google Sites lure impersonated a Codex download experience.
- The second-stage shell downloaded a Mach-O payload to /tmp/helper.
- The stage ran xattr -c, chmod +x, and then launched the payload.

ANALYTICAL ASSESSMENT

What the evidence supports

- The xattr action is a stronger host pivot than a single campaign domain or hash.
- The exact /tmp/helper path constrains overlap but reduces durability.
- A match does not prove AMOS execution, C2 success, theft, or attribution.

DETECTION ASSUMPTIONS

What must be validated

- Microsoft Defender for Endpoint records macOS process creation and command lines.
- The command line is complete and the same staging path is retained.
- Authorized workflows do not reproduce the complete xattr and path combination.

Confidence boundary

Cato assesses strong overlap with AMOS delivery activity, but the event alone cannot establish malware family, payload execution, credential theft, or post-execution C2. The exact path can change and local benign prevalence is unmeasured.



THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

ATTACK FLOW

01

Trusted lure

Sponsored search and Google Sites impersonate Codex.

02

User execution

The victim pastes a Base64-decoding command in Terminal.

03

Layered loader

Shell stages decode and execute obfuscated content.

04

Stage payload

The final Mach-O is written to /tmp/helper.

05

Clear and run

xattr -c precedes chmod +x and payload launch.

Observable core

A process event for xattr whose command line contains -c and the exact /tmp/helper staging path.

Non-observable boundary

Remote script content, prior quarantine state, chmod success, Mach-O execution outcome, C2 success, theft and actor identity.

DETECTION HYPOTHESIS

The trust-control impairment should remain visible in endpoint process telemetry.

If an attacker repeats the observed Fake Codex chain, process telemetry should show xattr -c applied to /tmp/helper. Legitimate activity can be separated through exact path, shell or Terminal lineage, file provenance, software ownership and change records.

REQUIRED TELEMETRY

DeviceProcessEvents

- Microsoft Defender for Endpoint on macOS.
- DeviceProcessEvents with full ProcessCommandLine.
- Stable device, time and event identifiers.

OPTIONAL ENRICHMENT

Context that improves disposition

- DeviceFileEvents for /tmp/helper.
- DeviceNetworkEvents and browser or Terminal lineage.
- File collection, hash, signer and notarization context.

UNAVAILABLE HERE

Do not infer

- Downloaded script and Mach-O contents.
- Extended attributes before and after the command.
- Execution, C2, credential theft or attribution outcome.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR - DeviceProcessEvents

Microsoft documents DeviceProcessEvents as process-creation and related endpoint telemetry populated by Microsoft Defender for Endpoint. It provides command line, device, account, parent-process and event context.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

The event establishes that xattr was launched with the observed arguments. It does not prove that the file existed, attributes were removed, or any later stage succeeded.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
Process event	DeviceProcessEvents	Primary process record.	REQUIRED
Executable	FileName, FolderPath	Identify xattr and its location.	REQUIRED
Command	ProcessCommandLine	Source-derived -c and /tmp/ helper filters.	REQUIRED
Event identity	Timestamp, DeviceName, ReportId	Documented unique-event combination.	REQUIRED
Device	DeviceId, DeviceName	Endpoint pivot.	REQUIRED
Account	AccountName, AccountUpn	Authorization context; population may vary.	OPTIONAL
Parent	InitiatingProcessFileName, InitiatingProcessCommandLine	Shell or Terminal lineage; population may vary.	OPTIONAL
Hash	SHA1	Executable enrichment; population may vary.	OPTIONAL

Data quality requirements

- Confirm MDE onboarding and process-event coverage on representative macOS assets.
- Verify full, untruncated command lines and xattr basename normalization.
- Retain the raw event and exact DeviceName, Timestamp and ReportId combination.
- Review every historical exact-pattern match with endpoint owners.

Known failure conditions

- macOS is not onboarded or the event is outside retention.
- ProcessCommandLine is absent or truncated.
- The actor changes the staging path or uses an API instead of xattr.
- Endpoint telemetry is impaired before execution.



DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

HUNTING QUERY

DETECTION OBJECTIVE

Find xattr clearing on the observed staged payload path.

Select only xattr process records whose command line contains both the observed clear option and /tmp/helper path.

ANALYTICAL LOGIC

Direct filters and investigable output.

Three direct source-derived predicates; no IOC network filter, hash, join, sequence, threshold, rarity, aggregation, regex or automatic attribution.

KQL · UNTESTED HUNT

```
// Fake Codex ClickFix - xattr clearing on staged /tmp/helper
// Classification: Hunting query - Untested implementation sketch
// Confidence: Medium
// Primary platform: Microsoft Defender XDR / Advanced Hunting
// Required telemetry: Microsoft Defender for Endpoint process events on macOS
//
// Evidence: Cato CTRL observed the second-stage shell downloading a Mach-O
// payload to /tmp/helper, invoking xattr -c on that file, then chmod +x and
// execution. This query isolates the directly observed anti-quarantine action.
// A match is an investigation lead; it does not prove AMOS execution,
// successful C2, credential theft, or attribution.

DeviceProcessEvents
| where FileName =~ "xattr"
| where ProcessCommandLine contains "-c"
| where ProcessCommandLine contains "/tmp/helper"
| project
    Timestamp,
    DeviceId,
    DeviceName,
    ReportId,
    ActionType,
    FileName,
    FolderPath,
    ProcessCommandLine,
    ProcessId,
    AccountName,
    AccountUpn,
    InitiatingProcessFileName,
    InitiatingProcessFolderPath,
    InitiatingProcessCommandLine,
    InitiatingProcessId,
    InitiatingProcessAccountName,
    InitiatingProcessAccountUpn,
    SHA1
| order by Timestamp desc
```

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested hunt	None	None	DeviceName + Timestamp + ReportId	Manual triage

What a match means

The endpoint recorded the exact source-observed xattr invocation and requires raw-event, file, lineage and ownership review.

What a match does not prove

File existence, attribute-removal success, chmod, Mach-O execution, AMOS compromise, C2 success, theft or attribution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the raw process event.
Verify the complete command line, executable path, host, account and event key.
- 02

Collect the staged file.
Acquire /tmp/helper if present and record hashes, file type, signer and notarization.
- 03

Rebuild lineage.
Review the initiating shell, Terminal, browser and preceding curl or zsh activity.
- 04

Check follow-on execution.
Look for chmod, helper execution and network activity without inferring success.
- 05

Validate ownership.
Confirm whether a developer, security test or deployment workflow created the event.

Escalation gate

Escalate when the exact event is unauthorized and corroborated by a newly created Mach-O, Base64-decoding shell activity, curl-to-zsh behavior, chmod, direct helper execution, suspicious network destinations or credential-access evidence.

Primary benign overlap

Developer, incident-response, malware-analysis or deployment activity may clear extended attributes from a temporary helper. Tune only through verified owner, script provenance, host scope and test window; never allowlist xattr, Terminal, /tmp or the filename globally.

INVESTIGATION PIVOTS

Device
macOS role, MDE health and user ownership.

Command line
Exact options, quoting and full target path.

Parent
Shell, Terminal or scripted launcher.

File
Creation time, hash, architecture and provenance.

Network
Download source and later destinations.

User
Paste context and authorized activity.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
Security validation	A controlled replay may intentionally reproduce the command.	Require approved operator, isolated host and test window.
Developer workflow	A build or test script may clear attributes on a helper binary.	Validate repository, script owner and reproducible provenance.
Incident response	Responders may manipulate a collected sample.	Confirm case ownership and acquisition timeline.

Baseline plan

- Search the maximum available DeviceProcessEvents retention.
- Review every complete-pattern match with asset owners.
- Measure command-line and parent-field completeness.
- Do not add a count, rarity or time-window threshold.

Validation procedure

- Create an innocuous /tmp/helper on an isolated onboarded macOS device.
- Execute the positive and path-based negative controls.
- Confirm DeviceName, Timestamp and ReportId plus command and parent context.
- Compare historical matches with software ownership and file evidence.

TEST CASES

CASE	EXPECTED RESULT
Run /usr/bin/xattr -c /tmp/helper on an innocuous file	Expected match with complete event fields.
Run xattr -c on a different temporary path	No match.
Run chmod +x /tmp/helper without xattr	No match by design.
Observe the local command but no Advanced Hunting event	Failure: repair endpoint telemetry before promotion.

Hunting Initial query	Candidate Current status	Production Measured precision	Optimized Stable feedback
---------------------------------	------------------------------------	---	-------------------------------------

Success

The controlled positive matches with stable fields, the path negative does not, and historical overlap is absent or explainable.

Rejection

Legitimate activity frequently reproduces the complete pattern and no durable provenance or lineage discriminator can be established.

Failure

The controlled event is absent, truncated or lacks a usable command line.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1553.001	Subvert Trust Controls: Gatekeeper Bypass	Covers the source-observed removal of extended attributes that may include macOS quarantine metadata before execution.

Detection coverage summary

Strong for the exact xattr -c and /tmp/helper combination when process telemetry is retained; weak for renamed paths, API-based attribute changes, missing command lines and cleared telemetry.

Residual risk

The actor can rotate paths, replace xattr with another mechanism, avoid quarantine metadata or impair EDR. User-execution, payload behavior and credential access require independent telemetry.

ANALYST CONCLUSION

A precise campaign hunt positioned at trust-control impairment.

Primary technical research directly supports the command and path, and Microsoft documents every required process field. Artifact mutability, unmeasured benign overlap and environment-dependent field population keep the implementation at Medium-confidence Hunting status.

REFERENCES

- 1. Cato CTRL, "When Trust Becomes the Payload in a Fake Codex ClickFix Campaign," 24 August 2026. <https://www.catonetworks.com/blog/cato-ctrl-when-trust-becomes-payload-in-fake-codex-clickfix-campaign/>
- 2. Microsoft Learn, "DeviceProcessEvents table in the advanced hunting schema," accessed 25 August 2026. <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>
- 3. MITRE ATT&CK, T1553.001, Gatekeeper Bypass; last modified 12 May 2026, accessed 25 August 2026. <https://attack.mitre.org/techniques/T1553/001/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	25 August 2026	Hunting	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.